

במפגש זה (המתועד במקור 13), המרצה מיכאל סקר את עולם החמ"ל הארגוני (SOC), את האתגרים בניהול עומס התראות, ואת המעבר למערכות הגנה פרו-אקטיביות מבוססות אוטומציה ובינה מלאכותית. להלן סיכום הנושאים המרכזיים מהשיעור:

## 1. מגמות שוק ועלויות סייבר

- **עלויות פריצה:** עלות פריצה ממוצעת ב-2025 עומדת על כ-7.4 מיליון דולר במגזר הבריאות, 5.5 מיליון דולר במגזר הפיננסי וכ-4 מיליון דולר בעולמות הטכנולוגיה 1.
- **שינוי במודל הגיוס:** ארגונים עוברים לגיוס ג'וניורים עם יכולת הפעלת כלי AI במקום חוקרים בכירים ויקרים, שכן הפרודוקטיביות הופכת דומה בעלות מצטברת נמוכה יותר 1, 2.
- **איומים חדשים:** התגלו חולשות יום-אפס (Zero-Day) חדשות במנגנוני SSO המאפשרות עקיפת הזדהות בקלות 1.

## 2. אתגר עומס ההתראות (Alert Fatigue)

- **כמויות מידע:** ארגונים גדולים (מעל 10,000 איש) מתמודדים עם עשרות אלפי התראות ביום 2.
- **הבעיה:** כ-98% מההתראות הן False Positive (התראות שווא) 2. ללא אוטומציה, אנליסטים אנושיים נאלצים לעבור על מאות התראות ביום, מה שמוביל לשחיקה ולדילוג על אירועים קריטיים בשל "עייפות התראות" 2-4.

## 3. ארכיטקטורת ה-SOC המודרני

- החמ"ל המודרני משלב שלושה מרכיבים (5) Technology, Process, People:
- **SIEM:** מערכת לאיסוף לוגים וחיפוש קורלציות ודפוסי התנהגות (6-8) UBA.
  - **SOAR:** מערכת המפעילה Playbooks (אוסף חוקים) לטיפול אוטומטי בתקלות ובאנומליות 5, 6, 9.
  - **XDR:** כלי הנותן תגובה אוטומטית מהירה וחסימה של איומים 6, 7.
  - **שכבות עבודה (Tiers):**
  - **Tier 1:** ניטור 24/7 וסינון ראשוני (סוגר כ-97% מההתראות) 10.
  - **Tier 2:** חקירה מעמיקה של אימפקט האירוע 10, 11.
  - **Tier 3:** צייד איומים (Threat Hunters) המבצעים הנדסה לאחור לאיומים חדשים 11.

## 4. מדדי ביצוע (KPI) וניהול אירועים

- ה-SOC נמדד לפי מספר זמני תגובה מרכזיים 12:
- **MTTD (Mean Time to Detect):** הזמן שחולף מחדירת התוקף ועד לזיהויו 12.
  - **MTTR (Mean Time to Respond):** הזמן הנדרש לנטרול האיום 12.
  - **Reopen Rate:** אחוז האיומים שחזרו לאחר שסומנו כטופלו 12.
  - **Accuracy Ratio:** היחס בין התראות שווא לאירועי אמת (הממוצע הוא 1-2 אירועי אמת לכל 1,000 התראות) 12.

## 5. SOC פנימי לעומת חיצוני (MSSP)

- **SOC חיצוני:** הקמה מהירה (4-8 שבועות), זול יותר וגמיש 13, 14.
- **SOC פנימי:** הקמה ארוכה (6-12 חודשים). הכרחי לארגונים ביטחוניים או פדרליים הדורשים שליטה מוחלטת ודיסקרטיות 13, 14.

## 6. המהפכה של ה-AI בפתרון תקלות

השימוש ב-AI (כמו Cloud Code וסוכנים אוטונומיים) מאפשר להגיע ל**שורש הבעיה (Root Cause)** במהירות אדירה. המערכת יודעת לסרוק קוד, למצוא את ה-PR הספציפי שגרם לחולשה ולזהות את המתכנת שביצע אותו 15. טכנולוגיה זו קיצרה זמני פתרון של אירועים מורכבים מ-32 **ימים לטווח של 8-26 שעות בלבד** 15, 16.

**לוגיסטיקה:** המבחן הסופי יהיה **אמריקאי**, בעוד שמטלת המילואימניקים תכלול שאלות פתוחות 17. המפגש הבא יוקדש לשאלות חזרה למבחן 16.